



FACULTY OF COMPUTER SCIENCE AND MATHEMATICS

CSF3233: (K2)

SEMESTER 2 SESSION 2025/2026

LAB REPORT 6

LAB 6: SCANNING VULNERABILITIES

LECTURER: SIR FAKHRUL ADLI BIN MOHD ZAKI

INSTRUCTOR: MADAM FATIN FATIHAH BINTI YAHYA

**PROGRAM NAME: BACHELOR OF COMPUTER SCIENCE
(SOFTWARE ENGINEERING) (HONS)**

Name	Matric no.
MUHAMMAD DANIAL BIN ZAINAL ARIFFIN	S72342

TASK 1: RUNNING GREEN BONE SECURITY MANAGER (GSM)

OBJECTIVE

To download and run the commercial trial version of OpenVAS known as Green Bone Security Manager (GSM) virtual machine.

TASK DESCRIPTION

For this task, the student needs to download GSM virtual machine from the given link and run it on the Virtual Box. GSM later will be used to scan the vulnerabilities of the Metasploitable virtual machine.

ESTIMATED TIME

60 Minutes

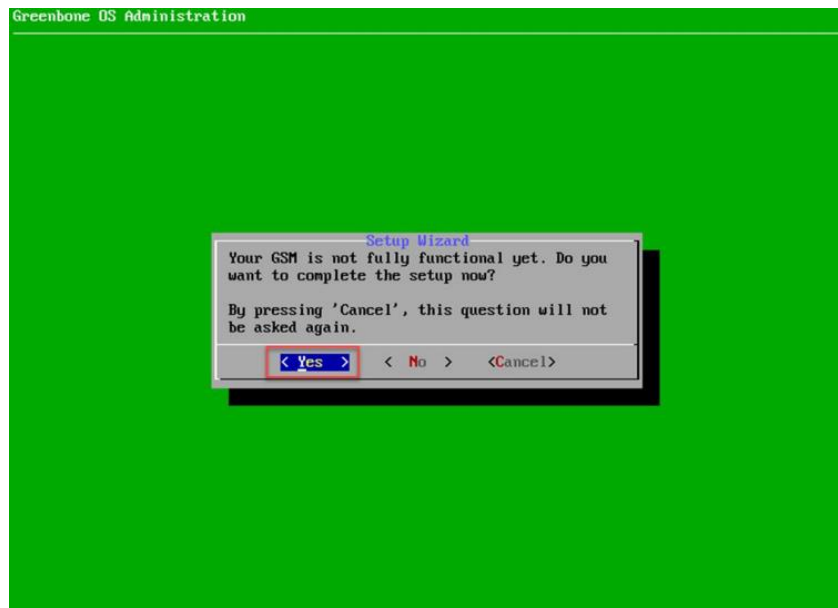
1. Welcome screen GSM virtual machine

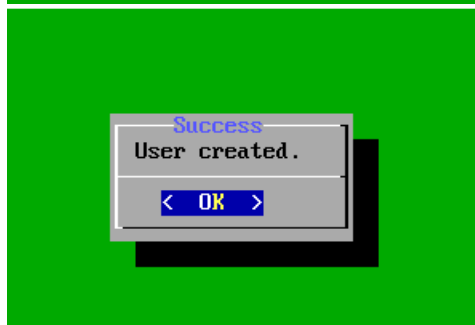
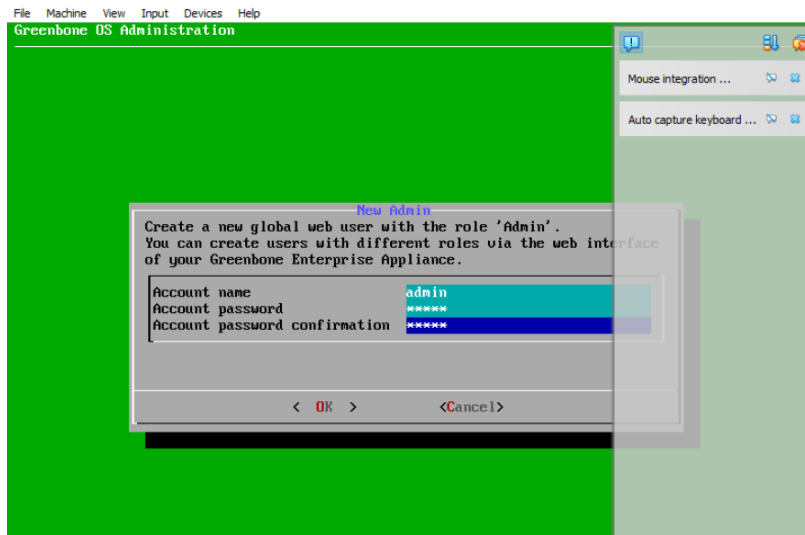
```
Welcome to Greenbone OS 21.04.1 (tty1)

The web interface is available at:

    http://192.168.138.3

gsm login:
```





Your connection is not private

Attackers might be trying to steal your information from **192.168.57.3** (for example, passwords, messages, or credit cards). [Learn more](#)

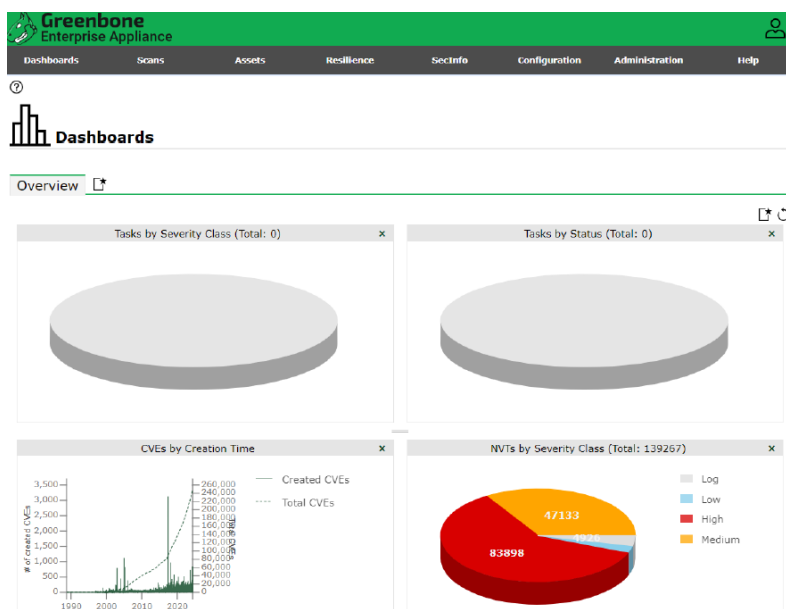
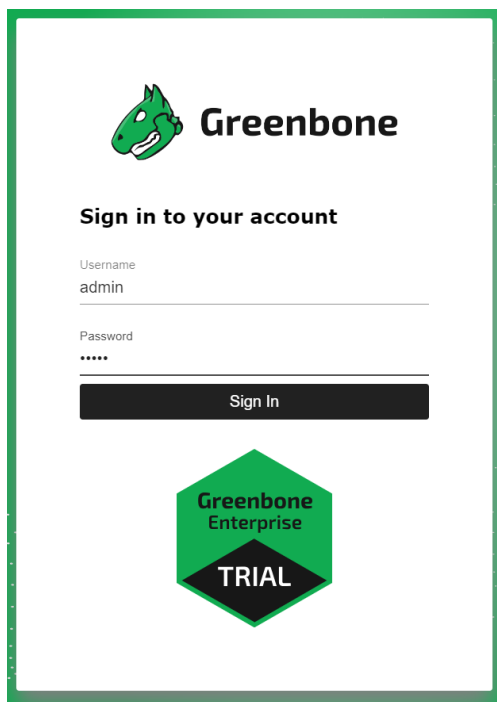
NET::ERR_CERT_AUTHORITY_INVALID

Hide advanced

Back to safety

This server could not prove that it is **192.168.57.3**; its security certificate is not trusted by your computer's operating system. This may be caused by a misconfiguration or an attacker intercepting your connection.

[Proceed to 192.168.57.3 \(unsafe\)](#)



Filter

New User

Login Name

S72342

Comment

Authentication

☒ Password

Roles

Admin

Groups

Host Access

☒ Allow all and deny

☐ Deny all and allow

Cancel

Save

1 - 2 of 2

Name ▲	Roles	Groups	Host Access	Authentication Type	Actions
admin	Admin		Allow all	Local	
S72342	Admin		Allow all	Local	

Apply to page contents

(Applied filter: sort=name first=1 rows=10)

1 - 2 of 2

TASK 2: SETTING UP THE NETWORK FOR METASPLOITABLE

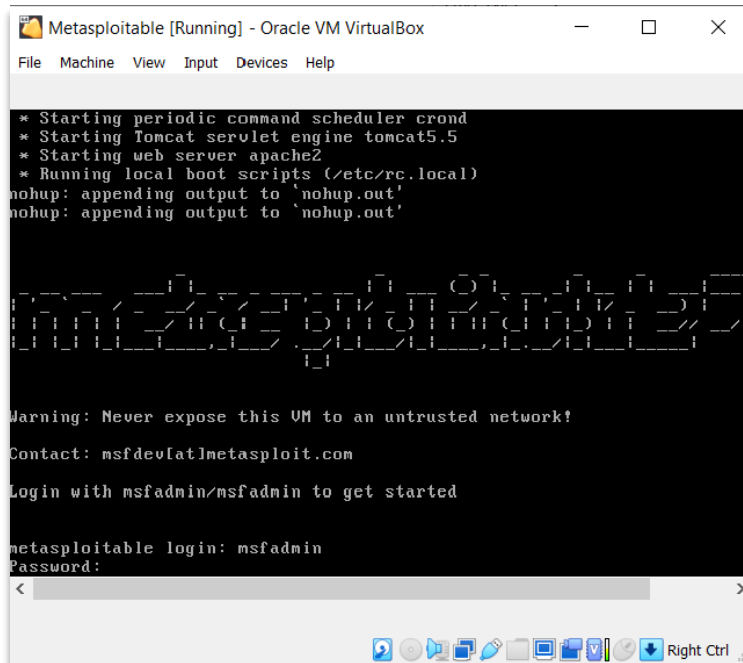
OBJECTIVE

To set up the network for Metasploitable virtual machine.

TASK DESCRIPTION

For this task, the student needs to set up the Host-only Adapter for the Metasploitable virtual machine. This setup will allow the GSM to scan the latter for its vulnerabilities.

ESTIMATED TIME

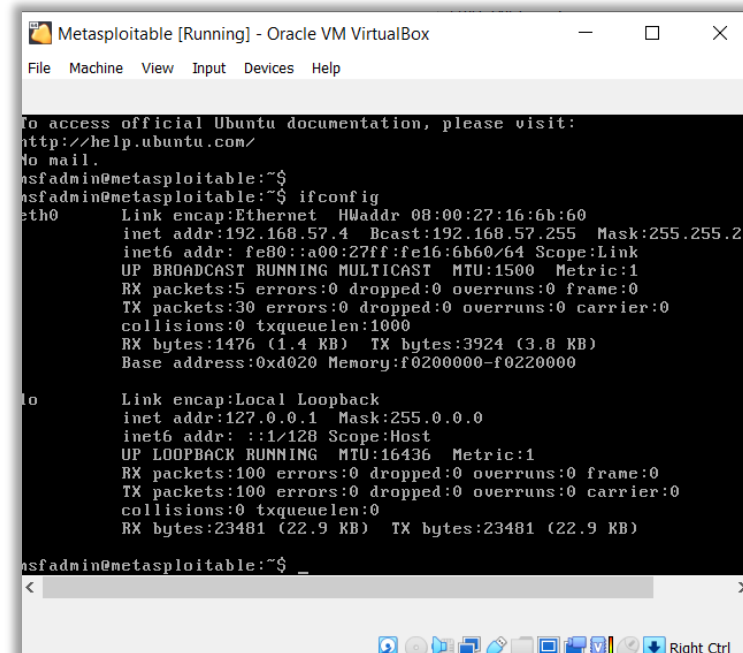


```
Metasploitable [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

* Starting periodic command scheduler crond
* Starting Tomcat servlet engine tomcat5.5
* Starting web server apache2
* Running local boot scripts (/etc/rc.local)
nohup: appending output to 'nohup.out'
nohup: appending output to 'nohup.out'

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
```



```
Metasploitable [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:16:6b:60
          inet addr:192.168.57.4  Bcast:192.168.57.255  Mask:255.255.255
          inet6 addr: fe80::a00:27ff:fe16:6b60/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:5 errors:0 dropped:0 overruns:0 frame:0
          TX packets:30 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1476 (1.4 KB)  TX bytes:3924 (3.8 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:100 errors:0 dropped:0 overruns:0 frame:0
          TX packets:100 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:23481 (22.9 KB)  TX bytes:23481 (22.9 KB)

msfadmin@metasploitable:~$ _
```

TASK 3: SCANNING THE VULNERABILITIES IN METASPLOITABLE

OBJECTIVE

To scan the vulnerabilities in Metasploitable using Greenbone Security Manager (GSM).

TASK DESCRIPTION

For this task, the student needs to run the GSM scanner to assess the vulnerabilities of the Metasploitable Virtual Machine.

ESTIMATED TIME

105 Minutes

STEPS:



Greenbone

Sign in to your account

Username

S72342

Password

.....

Sign In



ConfigurationAdministration

Targets

Port Lists

Credentials

Scan Configs

Report Formats

Scanners

Filters

Tags

New Target

Name

Metasploitable virtual machine

Comment

Hosts

Manual

192.168.57.4

From file

Choose File

No file chosen

Exclude Hosts

Manual

From file

Choose File

No file chosen

Allow simultaneous scanning via multiple IPs

Yes

No

Port List

All IANA assigned TCP

Alive Test

Scan Config Default

Credentials for authenticated checks

SSH

--

on port

22

SMB

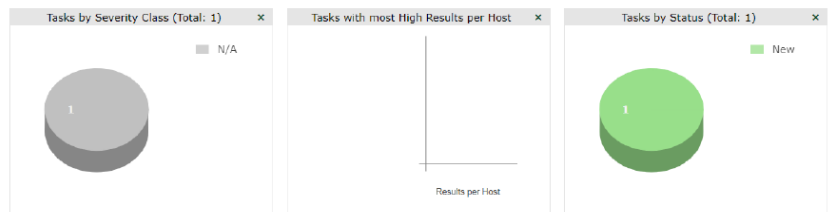
--

Cancel

Save

Filter

Tasks 1 of 1



Name	Status	Reports	Last Report	Severity	Trend	Actions
scanning metasploitable VM	New					

(Applied filter: apply_overrides=0 min_qcd=70 sort=name first=1 rows=10)

Dashboards

Scans

Assets

Resilience

SecInfo

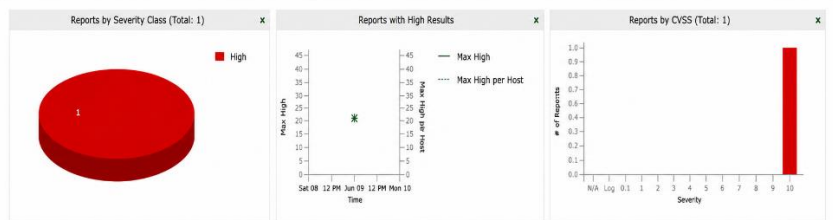
Configuration

Administration

Help

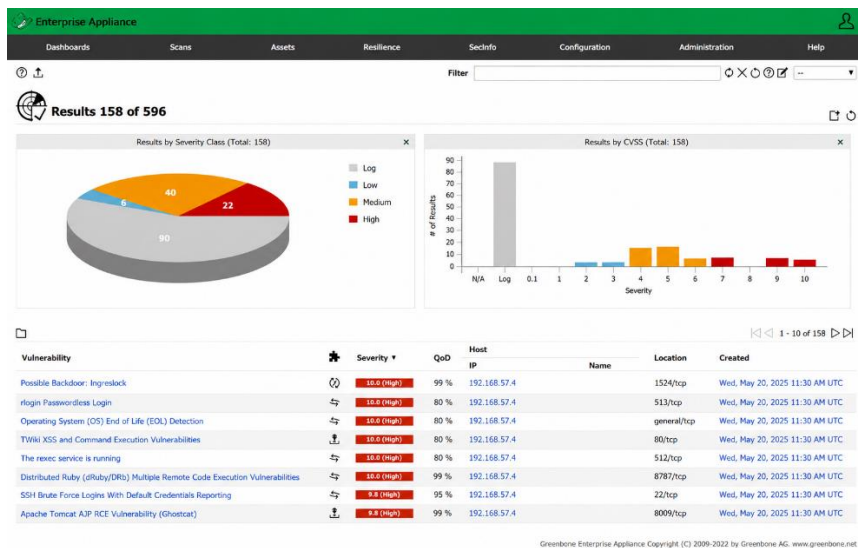
Filter

Reports 1 of 1



Date	Status	Task	Severity	High	Medium	Low	Log	False Pos.	Actions
Wed, May 20, 2025 11:30 AM UTC	Done	scanning metasploitable VM	10.0 (High)	22	40	6	90	0	

Apply to page contents



Based on your findings, answer the following questions:

a. Referring to the result of the scanning, complete the table of the severity class below:

Severity	Total
High	6
Medium	22
Low	40
log	90
Grand Total	158

b. What are vulnerabilities that have the highest severities? List them.

1. Possible Backdoor: Ingreslock
2. rlogin Passwordless Login
3. Operating System (OS) End of Life (EOL) Detection
4. TWiki XSS and Command Execution Vulnerabilities
5. The rexec service is running
6. Distributed Ruby (dRuby/DRb) Multiple Remote Code Execution Vulnerabilities

c. What is the vulnerability for port 513/tcp?

- rlogin Passwordless Login

d. List three (3) vulnerabilities with medium severity.

- Cleartext Transmission of Sensitive Information via HTTP
- Telnet Unencrypted Cleartext Login
- FTP Unencrypted Cleartext Login

- e. Based on the given information by GSM, how do we solve the "VNC Brute Force" vulnerability?
1. Disable VNC service if not required.
 2. Use strong authentication (not just a simple password).
 3. Implement account lockout after multiple failed login attempts.

REFLECTION QUESTIONS

1. In your own words, explain about Common Vulnerability Scanning System (CVSS) and Common Vulnerability Enumeration (CVE).
2. Explain the difference(s) between CVSS and CVE.
3. How many severity levels are there in the CVSS version 3.0?
4. Draw a table of CVSS3.0 severity levels and their base score range.
5. Observe the information provided at vuldb.com and answer the questions below: a. List three (3) most recent vulnerabilities and their severities. b. List three (3) latest available exploits. c. List three (3) vulnerabilities in current CVSS Top 5.

1. Common Vulnerability Scoring System (CVSS) and Common Vulnerability Enumeration (CVE):
 - **CVSS (Common Vulnerability Scoring System)** is an industry-standard framework for assessing the severity of security vulnerabilities. It produces a numerical score (from 0 to 10) based on the intrinsic characteristics of a vulnerability, such as how it can be exploited and its potential impact. This score helps organizations prioritize which vulnerabilities to fix first .
 - **CVE (Common Vulnerabilities and Exposures)** is essentially a dictionary or a list that provides a common, unique name (an ID) for publicly known cybersecurity vulnerabilities. It ensures that security professionals and tools can refer to the same issue using a standardized identifier.
2. The primary difference is their purpose:
 - CVE is for identification. It provides a unique ID and a description for a specific vulnerability. Think of it as a label or a name tag .
 - CVSS is for evaluation. It provides a score to measure the severity of the vulnerability identified by a CVE. Think of it as a report card or a rating
3. There are five (5) severity levels in CVSS version 3.0.
- 4.

Severity Rating	Base Score Range
None	0.0
Low	0.1 – 3.9
Medium	4.0 – 6.9
High	7.0 – 8.9
Critical	9.0 – 10.0

5a.

- CVE-2026-9605: A heap-based buffer overflow vulnerability in GNU libredwg. Its severity is High (CVSS v3.1) .
- CVE-2026-6497: A server-side request forgery (SSRF) vulnerability in TinyFileManager. Its severity is Critical .
- CVE-2026-6451: A cross-site request forgery (CSRF) vulnerability in a WordPress plugin. Its severity is Problematic (the equivalent of 'Medium' in CVSS v3)

b. All of the following vulnerabilities, which were recently published, have a public exploit available according to VulDB :

- CVE-2026-6497: Exploit available for a critical SSRF vulnerability in TinyFileManager.
- CVE-2026-6496: Exploit available for a critical path traversal vulnerability in TinyFileManager.
- CVE-2026-6493: Exploit available for a cross-site scripting (XSS) vulnerability in the Rally scheduling app.

c. The following are among the most recent critical vulnerabilities with high CVSS scores :

- CVE-2026-9605 (CVSS 7.4 / High): A vulnerability in GNU libredwg that leads to a heap-based buffer overflow.
- CVE-2026-23779 (CVSS not specified / Critical): A command injection vulnerability found in - Dell PowerProtect Data Domain.
- CVE-2026-23776 (CVSS not specified / Critical): An improper certificate validation vulnerability found in Dell PowerProtect Data Domain.